Kriptográfia és biztonság 10.

Digitális aláírások

Kézzel írott aláírások

Cél

- dokumentum eredetét bizonyítani
- dokumentum tartalmában megegyezni

Tulajdonságok egy ideális világban

- autentikus
- hamisíthatatlan
- nem használható többször
- integritás
- letagadhatatlan

Kérdés

- mi a digitális megfelelője?

Aláírás szimmetrikus kriptóval + TTP-vel

Ötlet: megbízható 3. fél (trusted third party, TTP)

- TTP kommunikál Alizzal és Bobbal a k_A és k_B szimm. kulcsokkal
- Aliz az m üzenet aláírását küldené Bob-nak

Protokoll

1. Aliz elküldi ezt: $E_{k_A}(m)$ a TTP-nek
2. TTP kiszámolja m-et és gyárt egy ($cert(m, A)$) tanúsítványt
3. titkosítja az egészet k_B-vel és küldi Bob-nak
4. Bob visszafejti és megkapja m és $cert(m, A)$-t

- tulajdonságok:
  - autentikus ✓
  - hamisíthatatlan ✓
  - nem használható többször ✓
  - integritás ✓
  - letagadhatatlan ✓

Aláírás szimmetrikus kriptóval + TTP-vel

Támadás

- Bob megmutathatja az aláírt dokut Carol-nak
  1. elküldi ezt: $E_{k_B}(m|cert(m, A))$ a TTP-nek
  2. TTP kiszámolja m és $cert(m, A)$-t és ellenőrzi $cert(m, A)$-t
  3. ha OK, akkor elküldi ezt: $E_{k_C}(m|cert(m, A))$ Carol-nak
  4. visszafejti és elolvas mindent

- elméletben jól hangzik
- gyakorlatban komoly gondok...
  - nem hatékony
  - DOS támadás a TTP ellen
  - a TTP maga!!!

Aláírás nyilvános kulcsú kriptóval

Ötlet

- Aliz generál pk_A, sk_A nyilvános-titkos kulcspárt és nyilvánosságra hozza pk_A-t
- Aliz az m üzenet aláírását küldené Bob-nak

Protokoll

1. Aliz elküldi ezt: $(m|E_{sk_A}(m))$ Bob-nak
2. Bob ellenőrzi az aláírást a második rész visszafejtésével (pk_A-val)

- sokkal jobb:
  - TTP nélkül ✓
  - autentikus ✓
  - hamisíthatatlan ✓
  - nem használható többször ✓
  - integritás ✓
  - letagadhatatlan ✓

Aláírás nyilvános kulcsú kriptóval

Protokoll

1. Aliz elküldi ezt: $(m|E_{sk_A}(m))$ Bob-nak
2. Bob ellenőrzi az aláírást a második rész visszafejtésével (pk_A-val)

- de még nem az igazi:

probléma újrahasználni a dokumentumot **és** az aláírást **együtt**
megoldás timestamp
probléma nem hatékkony
megoldás m egyirányú hash-ét titkosítani

Digitális aláírás vs. MAC

- digitális aláírás = nyilvános kulcsú megfelelője a MAC-nek
- közös cél: integritás védelem
- aláírásoknal egyszerubb kulcs kezelés
  - több fogadó
  - egy aláírás vs. különböző MAC tag-ek
- aláírás nyilvánosan ellenőrizhető
- aláírás átadható
- letagadhatatlan
  - szerződés aláírását bizonyítani harmadik félnek
  - MAC nem tudja
- hatékonyság: MAC-ek 2-3 nagysáégrenddel gyorsabbak

Digitális aláírás: definíció

Definíció

Egy aláírási séma egy $(Gen, Sign, Vrfy)$ *hármas, ha:*

Kulcs-generálás Gen *az* 1^n *biztonsági paraméterre kiad egy* (pk, sk) *nyilvános-titkos kulcspárt*

Aláírás $Sign$ *kiadja az* $\sigma := Sign_{sk}(m)$ *aláírást* $\forall m \in \{0,1\}^*$ *üzenetre*

Ellenőrzés $Vrfy$ *kiad egy* $b := Vrfy_{pk}(m, \sigma)$ *bitet, ami* $b = 1$*, ha az aláírás érvényes és 0 egyébként.*

A sémának korrektnek kell lennie: tetszőleges paraméterekre

$$Vrfy_{pk}(m, Sign_{sk}(m)) = 1.$$

Digitális aláírás biztonsága

Hogyan támadjuk?

- a támadó a következőket csinálja:
  1. néhány üzenet aláírását megkérdezi Aliztól
  2. számolgat
  3. gyárt egy *hamisítványt*: egy érvényes σ valamely új m-re
- ha ez „nehéz”, akkor biztonságos

Definíció

Egy aláírási séma biztonságos, ha $\forall$ PPT támadó egy m üzenethez tartozó érvényes σ aláírást csak elhanyagolható valószínuséggel tud generálni σ' aláírások lekérdezése után $m' \neq m$ esetén.

RSA aláírás – textbook változat

RSA paraméterek

- p, q nagy prímek, $N = p \cdot q$
- $e, d \in \mathbb{Z}$, ahol $ed \equiv 1 \mod \varphi(N)$

Textbook RSA aláírás

Gen: $pk = (N, e), sk = (p, q, d)$

$Sign$: adott sk és $m \in \mathbb{Z}_N^*$ esetén $\sigma :\equiv m^d \mod N$

$Vrfy$: adott pk és $m \in \mathbb{Z}_N^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow m \equiv \sigma^e \mod N$

RSA aláírás – textbook változat elemzése

Textbook RSA aláírás

Gen: $pk = (N, e), sk = (p, q, d)$

$Sign$: adott sk és $m \in \mathbb{Z}_N^*$ esetén $\sigma :\equiv m^d \mod N$

$Vrfy$: adott pk és $m \in \mathbb{Z}_N^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow m \equiv \sigma^e \mod N$

- korrekt ✓
- no-message támadás:
  - tetszőleges $\sigma \in \mathbb{Z}_N^*$-re legyen $m \equiv \sigma^e$.
  - (m, σ) egy jó hamisítvány...
  - kontra: a támadónak nem lehet hatása m-re
  - pro: de néha mégis...

RSA aláírás – textbook változat elemzése

Textbook RSA aláírás

Gen: $pk = (N, e), sk = (p, q, d)$

$Sign$: adott sk és $m \in \mathbb{Z}_N^*$ esetén $\sigma :\equiv m^d \mod N$

$Vrfy$: adott pk és $m \in \mathbb{Z}_N^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow m \equiv \sigma^e \mod N$

- hamisítvány **bármely** üzenetre:
  - $m \in \mathbb{Z}_N^*$ tetszőleges üzenet
  - támadó választ $m_1 \in_R \mathbb{Z}_N^*$ és $m_2 :\equiv m/m_1 \bmod N$
  - lekérdezi σ_1, σ_2 aláírásait m_1, m_2-nek
  - $\sigma :\equiv \sigma_1 \cdot \sigma_2 \bmod N$ egy érvényes aláírás m-re

RSA aláírás – Hashed RSA

- alapötlet: **az üzenet hash-ét** aláírni

Hashed RSA aláírás

Gen: legyen $H : \{0,1\}^* \mapsto \mathbb{Z}_N^*$ egy ütközésmentes hash-fv és $pk = (N, e, H(.)), sk = (p, q, d)$

$Sign$: adott sk és $m \in \{0,1\}^*$ esetén $\sigma :\equiv H(m)^d \bmod N$

$Vrfy$: adott pk és $m \in \{0,1\}^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow H(m) \equiv \sigma^e \bmod N$

RSA aláírás – Hashed RSA elemzése

Hashed RSA aláírás

Gen: legyen $H : \{0,1\}^* \mapsto \mathbb{Z}_N^*$ egy ütközésmentes hash-fv és $pk = (N, e, H(.)), sk = (p, k, d)$

$Sign$: adott sk és $m \in \{0,1\}^*$ esetén $\sigma :\equiv H(m)^d \bmod N$

$Vrfy$: adott pk és $m \in \{0,1\}^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow H(m) \equiv \sigma^e \bmod N$

- korrekt ✓
- no-message támadás:
  - tetszőleges $\sigma \in \mathbb{Z}_N^*$ kiszámolja $m' :\equiv \sigma^e$
  - keres $m \in \{0,1\}^*$, amire $H(m) = m'$
  - ha $H(.)$ nehezen invertálható, akkor nehéz

RSA aláírás – Hashed RSA elemzése

Hashed RSA aláírás

Gen: legyen $H : \{0,1\}^* \mapsto \mathbb{Z}_N^*$ egy ütközésmentes hash-fv és $pk = (N, e, H(.)), sk = (p, k, d)$

$Sign$: adott sk és $m \in \{0,1\}^*$ esetén $\sigma :\equiv H(m)^d \bmod N$

$Vrfy$: adott pk és $m \in \{0,1\}^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow H(m) \equiv \sigma^e \bmod N$

- hamisítvány **bármely** üzenetre:
  - keres $m, m_1, m_2 \in \{0,1\}^*$ üzeneteket, amire $H(m) \equiv H(m_1) \cdot H(m_2) \bmod N$
  - ha $H(.)$ nehezen invertálható, akkor ez is nehéz

RSA aláírás – Hashed RSA elemzése

Hashed RSA aláírás

Gen: legyen $H : \{0,1\}^* \mapsto \mathbb{Z}_N^*$ egy ütközésmentes hash-fv és $pk = (N, e, H(.)), sk = (p, k, d)$

$Sign$: adott sk és $m \in \{0,1\}^*$ esetén $\sigma :\equiv H(m)^d \bmod N$

$Vrfy$: adott pk és $m \in \{0,1\}^*$, $\sigma \in \mathbb{Z}_N^*$ az output 1 $\Leftrightarrow H(m) \equiv \sigma^e \bmod N$

- emléletben
  - $\nexists$ ismert hash-fv, ami biztonságos a szigorú értelemben
  - ha $H(.)$ PRF, akkor biztonságos
- gyakorlatban
  - randomnak látszó hash jó lesz (pl. SHA-3)

DLOG alapú aláírások: ElGamal

DLOG paraméterek

- G ciklikus csoport, $q = |G|, g \in G$ generátor, G-ben nehéz a DLOG

ElGamal aláírás

Gen legyen q nagy prím, $G =< g >, |G| = q$ és $x \in_R \mathbb{Z}_q$. A kulcsok: $sk := x$ és $pk = (G, g, q, g^x)$.

Sign legyen $k \in_R \mathbb{Z}_q, r = g^k, s \equiv (k^{-1}(m - xr)) \bmod q$. Ekkor $\sigma = (r, s)$

Vrfy az output 1 $\Leftrightarrow r^s y^r = g^m$

előnyök
- drága számításokat off-line
- üzenettől függő számítások gyorsak

hátrányok
- nagyobb σ, mint az RSA-nál
- σ „elrejti” m-et